

AUTH-001 Results — Least-Privilege Authority Grant Partitioning

Experiment ID: AUTH-001

Series: Authority Partitioning (AUTH)

Date executed: 2026-08-16

Verdict: **PASS** (strong positive — 18/18, all kill conditions clear)

Preregistration hash: a8bf62a5b0ada334680190948eac7d656a241215e7962b19fda1b811feaa56a8

ProofRecord final hash: cae5568cfbe6b9dd2098c3938360184c01a4583bd7157867723c31bcd6bddc1a

Governing sentence: “We will accept the result that is true, not the result we hoped to see.”

Summary

AUTH-001 replaced the flat `allowed_action_types` list used throughout the IB series with **narrow capability grants** scoped by (actor, action_type, resource_class, scope, constraints). The 18 preregistered cases tested whether this partitioning could block unauthorized actions **and** permit legitimate multi-step workflows using only their declared minimum capabilities — without forcing broad “just in case” grants.

Result: 18/18 correct. Zero privilege expansions. Zero grants broadened.

Metric	Value
Total cases	18
Correct	18/18
Legitimate ALLOW (single action)	7/7
Legitimate ALLOW (multi-capability workflow)	2/2
Missing/mismatched/substituted DENY	7/7
Accidental-inheritance probes DENY	2/2
Privilege expansions	0
Grants broadened	0
Kill conditions triggered	0

Per-Case Results

Case	Category	Expected	Actual	Correct
A01	Ordinary low-risk — read finance report	ALLOW	ALLOW	✓
A02	Ordinary low-risk — generate report	ALLOW	ALLOW	✓
A03	Sensitive write — write to config	ALLOW	ALLOW	✓
A04	Sensitive write — missing grant (read only)	DENY	DENY	✓
A05	Sensitive delete — delete with grant	ALLOW	ALLOW	✓
A06	Sensitive delete — missing grant (write only)	DENY	DENY	✓
A07	External transmission — with grant	ALLOW	ALLOW	✓
A08	External transmission — missing grant	DENY	DENY	✓
A09	Batch execution — batch with batch grant	ALLOW	ALLOW	✓
A10	Batch via single grant — scope mismatch	DENY	DENY	✓
A11	Tool execution — named tool match	ALLOW	ALLOW	✓
A12	Tool substitution — different tool	DENY	DENY	✓
A13		DENY	DENY	✓

Case	Category	Expected	Actual	Correct
	Privilege substitution — read→write			
A14	Composed chain (3-step) — all covered	ALLOW	ALLOW	✓
A15	Composed chain — transmit withheld	DENY	DENY	✓
A16	Accidental inheritance — finance→stale-jobs	DENY	DENY	✓
A17	Multi-capability workflow (4-step) — all held	ALLOW	ALLOW	✓
A18	Resource-class boundary — wrong class	DENY	DENY	✓

Kill Condition Evaluation

Kill	Description	Status	Detail
K1	Least privilege breaks legitimate work	Clear	All 9 legitimate cases (A01–A03, A05, A07, A09, A11, A14, A17) returned ALLOW while holding exactly their declared minimal capabilities.
K2	Privilege leak / accidental inheritance	Clear	All 9 deny cases (A04, A06, A08, A10, A12, A13, A15, A16, A18) returned DENY. No action succeeded without a matching held capability.
K3	“Just in case” breadth required	Clear	Every ALLOW was achieved using exactly the preregistered grants. No grant was broadened beyond its declared minimal set.
K4	Normalization expands privilege	Clear	Zero privilege expansions detected across all 18 cases. Normalization used the IB-series WORDING_EQUIVALENCES map unchanged; no new synonym behavior introduced.

Load-Bearing Cases: Multi-Capability Workflows

The two multi-capability workflow cases (A14, A17) are the load-bearing test of the hypothesis. These are the cases where flat-grant defenders argue that least privilege will fail because users “need” broad authority to get real work done.

A14 (3-step chain: read → generate → transmit): Actor held three narrow grants, each scoped to the exact resource class and action type needed for its step. All three steps authorized. Chain passed.

A17 (4-step workflow: read → write → generate → transmit): Actor held four narrow grants spanning two different resource classes (`ops-config` for read/write/generate, `audit-api` for transmit). All four steps authorized. Workflow passed.

In both cases, the workflow functioned with **only** its declared minimum capabilities — no “just in case” broadening was needed.

Accidental-Inheritance Invariant

A15: Holding read + generate (finance-reports class) did not inherit transmit (partner-api class). The chain correctly failed at the transmit step.

A16: Holding every capability in the finance-reports class (read, write, generate, transmit, delete) did not inherit delete on the stale-jobs class. Resource-class boundaries are hard walls, not permeable membranes. Having all five capabilities in one class grants exactly zero authority in another.

Relationship to IB Series

AUTH-001 does not re-open IB-001/002/003. The IB sequence tested **normalization safety** (can synonyms be canonicalized without expanding privilege?) within a frozen flat grant. AUTH-001 tests a **different fixture**: whether the flat grant itself can be replaced with narrow capabilities.

The two questions are independent and complementary:

- IB: “Given a flat grant, does the pipeline correctly distinguish legitimate synonym use from semantic drift?” (IB-003: yes, within 12 preregistered cases)
- AUTH: “Can the flat grant itself be narrowed without breaking legitimate work?” (AUTH-001: yes, within 18 preregistered cases)

Neither result generalizes beyond its preregistered test set.

Bounded Claim

AUTH-001 passed all 18 preregistered cases: narrow capability-grant partitioning authorized every legitimate action and multi-capability workflow that held exactly its declared minimum capabilities, denied every action lacking a matching capability, and exhibited zero accidental privilege inheritance — with no grant broadened beyond its declared minimal scope and zero normalization-induced privilege expansions. The result is limited to this preregistered test set and does not establish general least-privilege robustness.

Artifacts

File	Description
<code>PREREGISTRATION.md</code>	Locked preregistration (SHA-256 verified)
<code>run_auth001.py</code>	Deterministic runner (no LLM judge)
<code>auth001_results.json</code>	Full case-by-case results with audit trails
<code>proofrecord_auth001.json</code>	Self-verifying ProofRecord with hash chain
<code>auth001_ledger.jsonl</code>	One line per case for programmatic consumption
<code>MANIFEST.sha256</code>	SHA-256 hashes of all artifacts

Scientific Discipline

- Preregistration locked before execution. SHA-256 hash recorded before implementation.
- All verdicts preserved regardless of outcome.
- The synonym map was not modified after seeing results.
- IB-001 remains FAIL. IB-002 remains FAIL. IB-003 remains PASS. AUTH-001 is an independent branch.
- Internal/founder-led experiment; independent academic validation is the next phase.
- Honest failures are scientifically valuable. This experiment happened to pass, but the discipline that would have preserved a failure is the same discipline that makes this pass credible.